

CC Mod 4

Security in Cloud

The introduction of cloud computing creates numerous benefits for consumers of computing services but it also has security concerns associated with it. In addition to most security risks present in the traditional computing environment, cloud computing brings a new set of security issues with it. These issues emerge basically due to the massive sharing of infrastructure and resources which is an inherent feature of the utility service model.

Security is developing resistance to damage or protecting a system from any harm. It is a major concern for any computing system and also for the cloud computing system too. Computing system security means protection of the system itself and also of the data that it stores.

The security issues associated with cloud computing can be viewed from two angles: as the concerns of cloud providers (providing SaaS, PaaS or IaaS) and the concerns of the service consumers. The provider must ensure security of its own infrastructure as well as of the clients' data and applications. On the other hand, the consumers must verify and make sure that the provider has employed all possible security measures to make the services secure. Experience and expertise of the provider plays a significant role in this context. The relationship between the consumer and the service provider is also important in establishing a robust security system. Providers must establish a trust relationship with its consumers. Both parties should have a clear idea about their own responsibilities towards security management. To understand the risk in terms of how providers implement and manage security, the consumers can employ technical experts. Ultimately it is the responsibility of the consumers to ensure the safety of their application and data since a larger part of the job moves towards the provider's end and most often (particularly in public cloud) consumers have very little control over the entire environment. For ensuring security of the computing environment, it is often up to the consumer to initiate the inquiry that makes the process rolling. The on-premises private cloud deployments, though, decrease the risks associated to some extent.

Threat is an event that can cause harm to a system. It can damage the system's reliability and demote confidentiality, availability or integrity of information stored in the system.

Vulnerability refers to some weaknesses or flaws in a system (hardware, software or process) that a threat may exploit to damage the system. It refers to security flaws that poses the threat to a system increasing the chance of an attack to be successful.

Risk is the ability of a threat to exploit vulnerabilities and thereby causing harm to the system. Risk occurs when threat and vulnerability overlap.

Security Threats:

The security threat concerns in cloud computing can be categorized in following three sections:

- Threats to Infrastructure: Application level, host level or network level infrastructure security threats are no new issues introduced by cloud. The only difference to understand here is the share of responsibilities that both provider and consumer have, to safeguard the system. The threats to cloud computing infrastructure have to be studied from different perspectives, although almost all of these threats were present in any traditional distributed system also. Virtualization protects the computing infrastructure of cloud to some extent but at the same time it brings a new sort of security complexity which should be handled very delicately.
- Threats to Information: Apart from conventional threats to information, the cloud computing introduces new security concerns as consumers' (both organization and individual) data stays under the control of third-party cloud provider.
- Threats to Access Control: As the trust boundary expands beyond an organization's own control (especially in public cloud), proper authentication and authorization management for applications in the cloud is a very vital issue for security.

While discussing about security in cloud computing, one must keep two important and distinguishing points in mind:

- The cloud computing model itself has some unique security concerns associated with it which surfaced due to sharing of infrastructure or multi-tenancy features.
- When a cloud is deployed outside the control boundary of a consumer organization it brings a new set of security concerns.

In this regard, the public cloud is the most critical case to study. So, when cloud security is talked about, it mainly focuses on public cloud deployment which covers all of cloud related security concerns. In the subsequent part, infrastructure security concerns, information security means and access control mechanisms have been discussed.

Information security:

One concern of the cloud service consumers is related to the unauthorized access to confidential information and the data theft. In cloud computing, there must be a policy for securing data both during transfers between entities or when it is kept in rest. Three fundamental principles of information security such as confidentiality, integrity and availability are important pillars of cloud software security as well. They together are known as the CIA-triad and should be managed carefully for security of any information system. Cloud computing systems deal with user's confidential information and the CIA-triad is a vital issue there.

Confidentiality: Confidentiality deals with the threat of illegal disclosure of the users' confidential data. To maintain confidentiality of information and to make a secure cloud system (or any networked computing environment), the following issues should be taken care of with utmost precision.

- Encryption: Through encryption, the information is scrambled so that no unauthorized access can interpret it. Only authorized entities can understand it after decryption. Strength of encryption depends on the robustness and quality of the encryption algorithm.
- Traffic analysis: For information in transit to maintain confidentiality, the measures should be taken against traffic analysis attack. Traffic analysis investigates for sudden change in traffic activity (like rate, volume, source or destination of traffic) which may indicate as some incident is taking place. Counter-measures against this attack can be taken by masking the source and destination hosts and by maintaining a near-constant rate of traffic flow.
- Covert channels: Hackers often try to receive information by establishing secret communication paths known as covert channels. They generally do this by studying the timing of messages passing or through utilizing some vulnerability.

Although virtualization adds protection to the physical resources, a covert channel can break the isolation of the virtualization platform. Dynamic nature of the cloud environment also causes the risks related to covert channel problems. Covert channel particularly exploits imperfections in the shared resources of the elastic cloud environment. Apart from encryption, traffic analysis and covert channel issues as discussed above, protecting intellectual property (IP) of information through copyright law is also important in maintaining information confidentiality.

Integrity: Integrity of information guarantees against intentional or unintentional alteration. Information can be encrypted to maintain confidentiality but it may still get distorted. Loss of integrity in information can happen due to some deliberate attacks to alter it or there can be unintentional modifications where data is accidentally altered. Integrity of information can be protected through strict access control. Access to information is generally restricted by installing firewalls and intrusion detection systems. A policy must also be there to recover information from detectable errors, such as deletion and modification. Integrity is the protection of information against corruption.

Availability: Availability ensures reliable and timely access to information. It guarantees that information is available when needed. One threat in this regard is network-based attacks like denial-of-service attacks. A system must implement reliable network security mechanisms for these kinds of attacks. The other threat to availability is Cloud Service Providers' (CSPs) own accessibility by denying the legitimate access to computing resources. This problem can be avoided by using backups and redundant systems.

Identity Management & Access Control: Identity management and access control (often termed as identification and access management or IAM) are primary functionalities needed for any secure computing system. The benefits of identification and access management are:

- Proper execution of IAM technique improves a system's operational efficiency through automation of user verification process.
- It protects a system and enhances the security of its application and information against harmful attacks.

IAM in the Cloud:

Identity and access management (IAM) play a crucial role in cloud computing, especially as the adoption of cloud services often extends an organization's trust boundary beyond its own control and into the domain of service providers. This shift can pose significant security challenges and may hinder cloud service adoption if not managed properly. Both service providers and consumers share the responsibility of ensuring secure identity and access control. Service providers must implement strong IAM mechanisms to safeguard their cloud environments against malicious activities. This is particularly important in public cloud settings, where the entire computing infrastructure is located outside the consumer organization's network boundary. To mitigate this loss of control, consumer organizations should deploy effective access control strategies such as authentication and authorization. Robust IAM in cloud computing relies on modern technologies, including biometric verification, smart cards, and the governance of access rights to ensure only authorized users can access resources. Additionally, organizations can delegate IAM responsibilities to identity management-as-a-service (IDaaS) providers, with several vendors—such as Symplified and Ping Identity—offering cloud-based identity management solutions.

Identity Management:

<i>Single Sign-On</i>	<i>Federated Identity System</i>
User can access multiple applications under SSO group by signing in once.	User can access multiple applications under a federation by signing in once.
User needs to enroll themselves uniquely to each of the applications under SSO group.	User enrolls in any one application only under a federation.
User is known by all of the applications.	One user is known by only one application which is the home application of that user.
All of the applications of a SSO group allow a single sign-on of user being done through any of the applications.	Enterprise applications under a federation allow a single sign-on of user done through the home application only.
User credential is checked by all of the applications individually without prompting.	User credential is checked only once by the home application.
Every application under a SSO group checks the user separately.	All of the applications under a federation trust the home application.

Cloud Security Design Principles:

The fundamental principles of the security design approach of any information system remain valid for cloud computing as well. Any software design methodology includes security as a primary objective. However, an intensely secure cloud system may ultimately deliver poor performance features. Hence, it is necessary to maintain a balance between security and performance.

Least Privilege: The least privilege principle states that any subject (user or process) should always be assigned the minimum required privileges to perform its task. A time limit should also be set to bind the period for which the subject can hold a resource to complete a task. This reduces the opportunity of any malpractice and prevents unauthorized access to sensitive information.

Defense in Depth: The defense in depth principle states to architect the protection system with multiple layers. This enhances the safety mechanism. If one layer is breached, the subsequent internal layers defend against the attack and provide protection to the system.

Fail Safe: System failure sometimes creates opportunities for security breaches. It becomes difficult to strictly maintain all access control principles during system recovery, and attackers may exploit this. The fail safe principle states that a system should be secure against threats even during crashes and must ensure that the safety of information is not compromised. In other words, system recovery from failure should return the system to a secure state to prevent unauthorized access.

Economy of Mechanism: A simple design of a security mechanism reduces the chances of errors in understanding and implementation. In case of an error, it becomes easier to identify and fix it. This is known as the economy of mechanism, which advocates for keeping the security design as small and simple as possible.

Open Design: There has always been debate on the strength and merit of security designs that are kept secret versus those that are open. For example, in encryption techniques, one opinion suggests that undisclosed algorithms are harder to break, while another suggests that revealing the algorithm for peer review is better, as it increases the chances of uncovering flaws. In cloud computing, where high security is critical in a multi-tenant environment, the open design principle suggests that security should not rely on the secrecy of the design itself.

Complete Mediation: The complete mediation principle ensures rigorous checking of access controls with every request. Any access by a subject to an object must be verified using an effective authorization process.

Least Common Mechanism: The least common mechanism principle discourages sharing the same security mechanisms among different components. When multiple components share the same security mechanism, the system becomes vulnerable—if one component is compromised, the entire system could be at risk.

Separation of Privilege: The separation of privilege principle recommends distributing a single privilege among multiple independent subjects (components or users), so that more than one authorization is required to perform an action. This protects the system from the malicious intent of a single user or component.

Weakest Link: As the saying goes, “a chain is only as strong as its weakest link.” Likewise, a system’s security is only as robust as its most vulnerable module. Attackers tend to identify the weakest points in a system’s defense to begin their attacks. Therefore, the security system must be continuously reviewed and reinforced to detect and eliminate these weak links.

Psychological Acceptability: Psychological acceptability emphasizes that authorized users should find the system as simple and easy to use as it was before the implementation of security mechanisms. In other words, the added security should not interfere with the user experience, and any complexity should remain hidden in the background.

Cloud Security Management Frameworks:

In cloud security management, responsibilities of consumers and providers vary depending on the service delivery model and service-level agreement. One should understand the trust boundary of the services in the cloud before planning for its security.

There are industry standard management frameworks that provide guidance to plan for security of cloud systems and govern the processes to protect the assets. The Information Technology Infrastructure Library (ITIL) and ISO (International Organization for Standardization) provide such service management frameworks which any mature computing organization may adopt to strengthen their security management systems.

ITIL: Information Technology Infrastructure Library (ITIL) is globally accepted as a security guideline for Information Technology Service Management (ITSM). ITIL was introduced by the Central Computer and Telecommunications Agency (CCTA) of the United Kingdom to meet business organizations' growing dependence on information technology. It provides guidelines for managing information technology services, including cloud computing services.

ISO 27001 / 27002: ISO 27001 (also known as ISO/IEC 27001) defines the mandatory requirements for an Information Security Management System (ISMS). It was jointly proposed by the International Organization for Standardization (ISO) and the International

Electrotechnical Commission (IEC). ISO 27001 focuses on management, while ISO 27002 provides necessary controls to support ISO 27001.

What elements do cloud security frameworks cover?

Cloud security frameworks typically cover at least one or more of the following elements.

1. **Data Security:** Encompasses measures to protect data at rest, in transit, and during processing. Encryption, access controls, and data masking are commonly employed techniques to ensure data confidentiality and integrity. By adhering to these practices, organizations can prevent unauthorized access and data breaches.
2. **Application Security:** Focuses on securing software that operates in the cloud. This includes implementing secure coding practices, vulnerability assessments, and regular security updates. A comprehensive application security strategy prevents attacks such as SQL injection, cross-site scripting, and other exploits targeting application vulnerabilities.
3. **Network Security:** Protects the infrastructure and network architecture. This includes deploying firewalls, intrusion detection and prevention systems (IDPS), and virtual private networks (VPN) to protect against unauthorized access and network attacks. Effective network security ensures that communication between cloud services and users is secure.
4. **Cloud Compliance:** Supports adherence to laws, regulations, and standards governing data protection and privacy in cloud environments. A cloud security framework ensures that organizations meet these compliance requirements, avoiding legal penalties and reputational damage. Compliance frameworks such as GDPR, HIPAA, and CCPA are considered, ensuring data privacy and security.

Host Security in Different Cloud Models

Host Security for SaaS (Software as a Service): In a SaaS model, the provider fully manages the servers, network, and applications. As a customer, you receive little to no information about the underlying host infrastructure. Applications run on virtual machines using Linux, Windows, or other OSes. Providers often do not share details like:

- Operating systems
- Patch levels
- Security measures
- Hypervisor configurations

This lack of transparency is often intentional, to prevent hackers from exploiting such details.

How Customers Can Gain Assurance:

- Sign a Non-Disclosure Agreement (NDA) and request a detailed security status.
- Request security assessment reports, like SAS 70 or SysTrust.
- Ask for security certifications, such as ISO 27002.

Note: SaaS providers are not required to disclose environmental details but may offer high-level SLAs for availability, data backup, and disaster recovery.

Host Security for PaaS (Platform as a Service): In a PaaS environment, host security resembles SaaS in some ways but differs in control and access:

- Customers get access to libraries and some kernel-level parameters.
- Root/administrator-level privileges are not provided.
- The server is shared by multiple developers, increasing the need for strict host security.
- Although the operating system is still hidden, PaaS users:
 - Have access to an abstraction layer above the OS.
 - Use APIs provided by the cloud provider to interact indirectly with this layer.

Host Security for IaaS (Infrastructure as a Service): In an IaaS model, customers have the highest level of access:

- Full control over the server operating system.
- Access to CPU, memory, network ports, bandwidth, and storage.
- Root or administrator privileges are provided.

User Responsibilities:

- Decide which OS modules and services to activate.
- Use APIs to:
 - Provision or replicate resources
 - Add/remove component
 - Decommission virtual hosts
 - Automation is highly recommended to dynamically manage resources and workloads efficiently.

Security Tips:

- Virtual hosts are internet-accessible—access control is crucial.
- Only open one port at a time, as needed.
- For Unix virtual hosts, commonly used port 22 for sFTP (Secure FTP), SSH (Secure Shell), SCP (Secure Copy)

Model	Main Security Risks	Security Measures
IaaS	Data breaches due to mis-configuration or weak access controls - Data theft if encryption is not enabled - Rogue accounts and unauthorized changes - Lack of compliance with regulations	- Encrypt data at rest and in transit (using your own keys when possible) - Implement robust access controls and identity management - Regular security audits and monitoring - Timely patch management of OS and apps - Backup data regularly and store securely - Ensure compliance with standards (e.g., GDPR, HIPAA)
PaaS	- Vulnerabilities in applications or platform - Insecure APIs - Data exposure due to weak app security - Complexity in detecting breaches	- Secure application code and use vulnerability scanning - Employ Web Application Firewalls (WAFs) - Use secure APIs and enforce API key management - Encrypt data at rest and in transit - Implement strong authentication and access controls - Conduct regular vendor and compliance assessments.
SaaS	- Data breaches from compromised credentials - Insider threats - Limited control over provider's security - Compliance and privacy concerns	- Configure user permissions and access controls (least privilege) - Use strong authentication (e.g., MFA) - Ensure provider supports encryption for data at rest and in transit - Regularly review and manage user accounts - Verify provider's compliance with privacy regulations - Ensure data backup and recovery plans are in place

Key Points for Each Cloud Model

IaaS (Infrastructure as a Service)

- You control the OS, applications, and data; the provider secures the physical infrastructure.
- Major risks include misconfiguration, lack of encryption, and unauthorized access.
- Security measures: Encrypt data, enforce least privilege access, audit systems, patch regularly, and ensure compliance.

PaaS (Platform as a Service)

- The provider manages infrastructure and runtime; you secure your applications and data.

- Risks stem from insecure coding, vulnerable APIs, and complex environments.
- Security measures: Secure development practices, encryption, access controls, secure API usage, and regular vulnerability scans.

SaaS (Software as a Service)

- The provider manages almost all security; you manage user access and data privacy.
- Main risks are unauthorized access, weak credentials, and provider-side breaches.
- Security measures: Configure strong access controls, use MFA, verify encryption, and ensure regulatory compliance.

Data Security Best Practices Across All Models

- Encryption: Always encrypt sensitive data at rest and in transit.
- Access Control: Apply the principle of least privilege and use strong authentication.
- Monitoring: Employ continuous monitoring and logging to detect suspicious activity.
- Compliance: Regularly assess compliance with regulations relevant to your industry.
- Backup: Ensure regular, secure backups and test recovery procedures.

By understanding the unique risks and implementing appropriate security measures for each cloud service model, organizations can significantly reduce their exposure to data breaches and ensure robust data protection in the cloud.